

SQL Basics: Reading & Attacking Databases

Databases Store the Crown Jewels

Users, passwords, credit cards, business secrets. SQL injection (SQLi) is the attack that reads/writes them through a web app. To defend and attack properly, you must speak SQL.

Core Queries

```
-- Everything
SELECT * FROM users;

-- Filter
SELECT username, role FROM users WHERE role = 'admin';

-- Count
SELECT COUNT(*) FROM logins WHERE success = 0;

-- Combined
SELECT u.username, u.email FROM users u
JOIN orders o ON o.user_id = u.id
WHERE o.amount > 1000;
```

UNION: The Injection Superpower

UNION combines results from two queries – and it's how attackers exfiltrate data when they only have a SELECT injection point.

```
-- Legit query (searches products)
SELECT name, price FROM products WHERE id = '$id'

-- Injection: id = 1 UNION SELECT username, password FROM users --
SELECT name, price FROM products WHERE id = '1'
UNION SELECT username, password FROM users -- '
```

If the app concatenates user input into the SQL string, the attacker adds columns to the result. The app then renders the password alongside the product name.

How Injection Happens (Bad Code)

```
# BAD – string concatenation
q = "SELECT * FROM users WHERE name = '" + username + "'"

# GOOD – parameterized
q = "SELECT * FROM users WHERE name = %s" # driver fills in
cursor.execute(q, (username,))
```

Parameterized queries (prepared statements) make the database treat user input as DATA, not as SQL. That is the #1 fix.

Detecting & Exploiting (Red Team View)

Test:

Input a single quote: `'` → error? Likely injectable

`1' OR '1'='1` → does it list more than it should?

`1 UNION SELECT NULL, NULL, NULL` → count columns by null error

Order columns until you find giants: `1 UNION SELECT username,password,NULL`

Always validate the injection only on YOUR OWN lab apps (DVWA, WebGoat, PortSwigger Academy).

Defending (Blue Team View)

Parameterized queries – always

Input validation/whitelisting – reject chars not expected

Least-privileged DB accounts (app user can't `DROP`)

Web Application Firewall (WAF) as defense-in-depth

Log + alert on suspicious patterns (`UNION`, `OR 1=1`, quote errors)